

SAE4.01

**WRITE UP : SÉCURISER UN
SYSTÈME D'INFORMATION**

Guyot Loïc
Sailliot Valentin
Jendryka Clément
Poiré Pierre

RT2-FI-A2

2024 - 2025

1/ Configuration Complète de la Maquette	3
1/ Coté Siège	3
Instructions spécifiques pour Tunnel GRE/IPsec:	7
2/ Coté Succursale	7
Instructions spécifiques pour Tunnel GRE/IPsec (coté droit):	11
Routeur haut central (Internet)	11
2/ Installation et Configuration de Base de Nginx sur Ubuntu	12
1.1. Mise à jour du Système et Installation de Nginx	12
2. Sécurisation de Nginx avec TLS/SSL	13
2.1. Génération d'un Certificat SSL	13
2.2. Configuration de Nginx pour HTTPS	13
3. Redirection de HTTP vers HTTPS	14
4. Configuration des En-têtes de Sécurité	14
5. Résultat final de la configuration :	15
Configuration du site connexion.php	17
Configuration de la page de redirection vers la page de connexion (index.html)	18
Configuration de la page login "index.php"	18
Configuration de la page d'inscription "inscription.php"	20
Création du login.php pour la redirection :	22
Mise en place du nom de domaine (DNS) :	24
Création de la BDD via Mysql :	26
3/ Sécurisation DNS avec DNSSEC	28
1. Objectifs	28
2. Environnement	28
3. Installation et Configuration Initiale du Serveur DNS	29
3.1 Installation de Bind9	29
3.2 Test de la résolution locale	29
4. Configuration Basique de la Zone DNS	30
4.1 Déclaration de la Zone	30
4.2 Fichier de Zone Non-Signée	30
4.3 Redémarrage du service Bind9	31
5. Mise en Place de DNSSEC	31
5.1 Génération des Clés	31
5.2 Signature de la Zone	32
5.3 Mise à Jour de la Configuration	32
6. Configuration pour sécurisation supplémentaire	33
6.1 Limitation d'accès aux requêtes DNS (ACL)	33
6.2 Renforcer la sécurité du système d'exploitation	34
6.3 Sauvegardes et redondance	34

6.4 Surveillance et alertes	35
7. Vérification de la Configuration DNSSEC	36
7.1 Vérification avec dig	36
7.2 Analyse avec Wireshark	37
8. Structure des Fichiers de Configuration.....	37
9. Conclusion	37
10. Fichiers de configurations.....	38
4/ Recommandations ANSSI : Checklist des mesures retenues, exclues ou non applicables.	43

1/ Configuration Complète de la Maquette

1/ Coté Siège

Configuration du Switch de couche 3

```
# Activation routage IP
enable
configure terminal
ip routing

# VLAN Admin
vlan 10
name Admin
exit

interface vlan 10
ip address 192.168.10.1 255.255.255.0
ip access-group ACL_VLAN10_LEFT in
no shutdown

# VLAN Production
vlan 20
name Production
exit

interface vlan 20
ip address 192.168.20.1 255.255.255.0
ip access-group ACL_VLAN20_LEFT in
no shutdown

# VLAN Service
vlan 30
name Service
exit

interface vlan 30
ip address 192.168.30.1 255.255.255.0
ip access-group ACL_VLAN30_LEFT in
no shutdown

# VLAN 200 (connexion ASA)
```

```
vlan 200
name ASA
exit

interface vlan 200
ip address 192.168.200.2 255.255.255.0
no shutdown

# Port access VLANs
interface GigabitEthernet1/0/1
switchport mode access
switchport access vlan 10

interface GigabitEthernet1/0/2
switchport mode access
switchport access vlan 20

interface GigabitEthernet1/0/3
switchport mode access
switchport access vlan 30

interface GigabitEthernet1/0/4
switchport mode access
switchport access vlan 200

# Route par défaut
ip route 0.0.0.0 0.0.0.0 192.168.200.1
```

Ainsi que les ACLs

```
ip access-list extended ACL_VLAN10_LEFT
permit ip any any

ip access-list extended ACL_VLAN20_LEFT
permit icmp 192.168.20.0 0.0.0.255 192.168.99.0 0.0.0.255 echo
permit icmp 192.168.20.0 0.0.0.255 192.168.99.0 0.0.0.255 echo-reply
permit icmp 192.168.20.0 0.0.0.255 192.168.98.0 0.0.0.255 echo
permit icmp 192.168.20.0 0.0.0.255 192.168.98.0 0.0.0.255 echo-reply
deny icmp 192.168.20.0 0.0.0.255 any echo
permit icmp any any echo-reply
permit ip any any
```

```
ip access-list extended ACL_VLAN30_LEFT
permit icmp 192.168.30.0 0.0.0.255 192.168.99.0 0.0.0.255 echo
permit icmp 192.168.30.0 0.0.0.255 192.168.99.0 0.0.0.255 echo-reply
permit icmp 192.168.30.0 0.0.0.255 192.168.98.0 0.0.0.255 echo
permit icmp 192.168.30.0 0.0.0.255 192.168.98.0 0.0.0.255 echo-reply
deny icmp 192.168.30.0 0.0.0.255 any echo
permit icmp any any echo-reply
permit ip any any
```

Configuration du Firewall - ASA

```
interface GigabitEthernet1/1
nameif inside
ip address 192.168.200.1 255.255.255.0
no shutdown

interface GigabitEthernet1/2
nameif outside
ip address 192.168.40.1 255.255.255.0
no shutdown

interface GigabitEthernet1/3
nameif dmz
ip address 192.168.99.1 255.255.255.0
no shutdown

route outside 0.0.0.0 0.0.0.0 192.168.40.2 1
route inside 192.168.10.0 255.255.255.0 192.168.200.2 1
route inside 192.168.20.0 255.255.255.0 192.168.200.2 1
route inside 192.168.30.0 255.255.255.0 192.168.200.2 1

policy-map global_policy
class inspection_default
inspect icmp
```

Configuration du Tunnel GRE/IPsec ainsi que les explications

```
configure terminal
crypto isakmp policy 10
encr aes
authentication pre-share
group 2
exit

# clé pré-partagée
crypto isakmp key TUNNELKEY address 192.168.60.1

# Configuration IPsec transform-set
crypto ipsec transform-set TSET esp-aes esp-sha-hmac

# ACL pour le trafic GRE
ip access-list extended GRE_TRAFFIC
permit gre host 192.168.50.1 host 192.168.60.1

# Application crypto-map
crypto map CRYPTOMAP 10 ipsec-isakmp
set peer 192.168.60.1
set transform-set TSET
match address GRE_TRAFFIC
exit

interface GigabitEthernet0/1
crypto map CRYPTOMAP

# Création du tunnel GRE sécurisé
interface Tunnel0
ip address 172.16.0.1 255.255.255.252
tunnel source GigabitEthernet0/1
tunnel destination 192.168.60.1
mtu 1476
exit

# OSPF routing
router ospf 1
network 192.168.40.0 0.0.0.255 area 0
network 192.168.50.0 0.0.0.3 area 0
network 172.16.0.0 0.0.0.3 area 0
```

Instructions spécifiques pour Tunnel GRE/IPsec:

- Créer une politique ISAKMP (Phase 1).
- Définir une clé pré-partagée correspondant entre les deux routeurs.
- Créer un IPsec transform-set.
- Définir une ACL autorisant le trafic GRE entre les deux routeurs.
- Appliquer une crypto-map sur l'interface publique du routeur.
- Configurer une interface Tunnel GRE avec adresses IP privées des tunnels, source et destination.

2/ Côté Succursale

Nous allons retrouver pratiquement la même configuration, seules les adresses IP vont changer !

Configuration du Switch de couche 3

```
# Activation routage IP
enable
configure terminal
ip routing

# VLAN Admin
vlan 11
name Admin
exit

interface vlan 11
ip address 192.168.11.1 255.255.255.0
ip access-group ACL_VLAN11_RIGHT in
no shutdown

# VLAN Production
vlan 21
name Production
exit

interface vlan 21
ip address 192.168.21.1 255.255.255.0
ip access-group ACL_VLAN21_RIGHT in
no shutdown
```



```
# VLAN Service
vlan 31
name Service
exit

interface vlan 31
ip address 192.168.31.1 255.255.255.0
ip access-group ACL_VLAN31_RIGHT in
no shutdown

# VLAN 210 (connexion ASA)
vlan 210
name ASA
exit

interface vlan 210
ip address 192.168.210.2 255.255.255.0
no shutdown

# Port access VLANs
interface GigabitEthernet1/0/1
switchport mode access
switchport access vlan 11

interface GigabitEthernet1/0/2
switchport mode access
switchport access vlan 21

interface GigabitEthernet1/0/3
switchport mode access
switchport access vlan 31

interface GigabitEthernet1/0/4
switchport mode access
switchport access vlan 210

# Route par défaut
ip route 0.0.0.0 0.0.0.0 192.168.210.1
```

Ainsi que les ACLs

```
ip access-list extended ACL_VLAN11_RIGHT
permit ip any any

ip access-list extended ACL_VLAN21_RIGHT
permit icmp 192.168.21.0 0.0.0.255 192.168.98.0 0.0.0.255 echo
permit icmp 192.168.21.0 0.0.0.255 192.168.98.0 0.0.0.255 echo-reply
permit icmp 192.168.21.0 0.0.0.255 192.168.99.0 0.0.0.255 echo
permit icmp 192.168.21.0 0.0.0.255 192.168.99.0 0.0.0.255 echo-reply
deny icmp 192.168.21.0 0.0.0.255 any echo
permit icmp any any echo-reply
permit ip any any

ip access-list extended ACL_VLAN31_RIGHT
permit icmp 192.168.31.0 0.0.0.255 192.168.98.0 0.0.0.255 echo
permit icmp 192.168.31.0 0.0.0.255 192.168.98.0 0.0.0.255 echo-reply
permit icmp 192.168.31.0 0.0.0.255 192.168.99.0 0.0.0.255 echo
permit icmp 192.168.31.0 0.0.0.255 192.168.99.0 0.0.0.255 echo-reply
deny icmp 192.168.31.0 0.0.0.255 any echo
permit icmp any any echo-reply
permit ip any any
```

Configuration du Firewall - ASA

```
interface GigabitEthernet1/1
nameif inside
ip address 192.168.210.1 255.255.255.0
no shutdown

interface GigabitEthernet1/2
nameif outside
ip address 192.168.41.1 255.255.255.0
no shutdown

interface GigabitEthernet1/3
nameif dmz
ip address 192.168.98.1 255.255.255.0
no shutdown

route outside 0.0.0.0 0.0.0.0 192.168.41.2 1
route inside 192.168.11.0 255.255.255.0 192.168.210.2 1
```

```
route inside 192.168.21.0 255.255.255.0 192.168.210.2 1
route inside 192.168.31.0 255.255.255.0 192.168.210.2 1

policy-map global_policy
class inspection_default
inspect icmp
```

Configuration du Tunnel GRE/IPsec ainsi que les explications

```
configure terminal
crypto isakmp policy 10
encr aes
authentication pre-share
group 2
exit

crypto isakmp key TUNNELKEY address 192.168.50.1

crypto ipsec transform-set TSET esp-aes esp-sha-hmac

ip access-list extended GRE_TRAFFIC
permit gre host 192.168.60.1 host 192.168.50.1

crypto map CRYPTOMAP 10 ipsec-isakmp
set peer 192.168.50.1
set transform-set TSET
match address GRE_TRAFFIC
exit

interface GigabitEthernet0/1
crypto map CRYPTOMAP

interface Tunnel0
ip address 172.16.0.2 255.255.255.252
tunnel source GigabitEthernet0/1
tunnel destination 192.168.50.1
mtu 1476
exit

router ospf 1
network 192.168.41.0 0.0.0.255 area 0
```

```
network 192.168.60.0 0.0.0.3 area 0
network 172.16.0.0 0.0.0.3 area 0
exit
```

Instructions spécifiques pour Tunnel GRE/IPsec (coté droit):

- Définir la politique ISAKMP.
- Configurer clé pré-partagée correspondant avec routeur gauche.
- Configurer IPsec transform-set identique.
- Configurer ACL GRE inversée par rapport au routeur gauche.
- Appliquer le crypto-map sur interface publique.
- Définir l'interface Tunnel GRE avec adresses inversées.

Routeur haut central (Internet)

```
interface GigabitEthernet0/0
ip address 192.168.50.2 255.255.255.252
no shutdown

interface GigabitEthernet0/1
ip address 192.168.60.2 255.255.255.252
no shutdown

router ospf 1
network 192.168.50.0 0.0.0.3 area 0
network 192.168.60.0 0.0.0.3 area 0
exit
```

2/ Configuration des Mots de Passe et de l'Accès SSH

1.1 Sur le site du Siège

Pare-feu ASA (ASA-SIEGE)

```
enable password AsaSieve1
hostname ASA-SIEGE
domain-name asa_siege.com

crypto key generate rsa modulus 2048

username admin password AsaSieve1

aaa authentication ssh console LOCAL

ssh version 2
ssh timeout 10
ssh 0.0.0.0 0.0.0.0 inside # Autoriser SSH depuis le réseau "inside"

password encryption aes
service password-encryption
```

⚠ mot de passe pour le pare-feu : **AsaSieve1**

Explication :

Ces commandes définissent le mot de passe d'activation, le nom d'hôte et le domaine du pare-feu ASA. La clé RSA est générée pour sécuriser les connexions SSH. Le compte « admin » est créé avec le mot de passe spécifié, et l'authentification SSH est activée en utilisant la base locale. Enfin, la commande *service password-encryption* permet de chiffrer les mots de passe dans la configuration.

Routeur du Siège (R1-SIEGE)

```
R1-SIEGE> enable
R1-SIEGE# configure terminal

! Définir le nom d'hôte et le domaine
R1-SIEGE(config)# hostname R1-SIEGE
R1-SIEGE(config)# ip domain-name R1_siege.com

! Configurer le mot de passe enable
R1-SIEGE(config)# enable secret R1Siege1

! Configuration de la console
R1-SIEGE(config)# line console 0
R1-SIEGE(config-line)# password R1Siege1
R1-SIEGE(config-line)# login
R1-SIEGE(config-line)# exit

! Configuration des lignes VTY pour SSH (utilisation de l'authentification locale)
R1-SIEGE(config)# line vty 0 4
R1-SIEGE(config-line)# login local
R1-SIEGE(config-line)# transport input ssh
R1-SIEGE(config-line)# exit

! Générer les clés RSA (2048 bits)
R1-SIEGE(config)# crypto key generate rsa modulus 2048

! Créer le compte admin local
R1-SIEGE(config)# username admin secret R1Siege1

! Forcer l'utilisation de SSH version 2 et activer le chiffrement des mots de passe
R1-SIEGE(config)# ip ssh version 2
R1-SIEGE(config)# service password-encryption

! Sauvegarder la configuration
R1-SIEGE(config)# end
R1-SIEGE# write memory
```

⚠ mot de passe pour le routeur : **R1Siege1**

Switch de couche 3 (L3-SIEGE)

```
Switch# enable
Switch# configure terminal

! Définir le nom d'hôte
Switch(config)# hostname L3-SIEGE

! Configurer le mot de passe enable
L3-SIEGE(config)# enable secret L3Siege1

! Configuration de la console
L3-SIEGE(config)# line console 0
L3-SIEGE(config-line)# password L3Siege1
L3-SIEGE(config-line)# login
L3-SIEGE(config-line)# exit

! Configuration des lignes VTY pour SSH avec authentification locale
L3-SIEGE(config)# line vty 0 4
L3-SIEGE(config-line)# login local
L3-SIEGE(config-line)# transport input ssh
L3-SIEGE(config-line)# exit

! Définir le domaine pour la génération des clés RSA
L3-SIEGE(config)# ip domain-name L3_siege.com

! Générer les clés RSA (2048 bits)
L3-SIEGE(config)# crypto key generate rsa modulus 2048

! Créer le compte admin
L3-SIEGE(config)# username admin secret L3Siege1

! Forcer SSH version 2 et activer le chiffrement des mots de passe
L3-SIEGE(config)# ip ssh version 2
L3-SIEGE(config)# service password-encryption

! Sauvegarder la configuration
L3-SIEGE(config)# end
L3-SIEGE# copy running-config startup-config
```

⚠ mot de passe pour le switch de couche 3 : **L3Siege1**

1.2 Sur le site de la Succursale

Pare-feu ASA (ASA-SIEGE – Succursale)

```
ASA-SIEGE(config)# enable password AsaSuc2
ASA-SIEGE(config)# hostname ASA-SIEGE
ASA-SIEGE(config)# domain-name asa_succursale.com

! Générer une clé RSA de 2048 bits
ASA-SIEGE(config)# crypto key generate rsa modulus 2048

! Création du compte admin avec le mot de passe
ASA-SIEGE(config)# username admin password AsaSuc2

! Activer l'authentification SSH locale
ASA-SIEGE(config)# aaa authentication ssh console LOCAL

! Configurer SSH
ASA-SIEGE(config)# ssh version 2
ASA-SIEGE(config)# ssh timeout 10
ASA-SIEGE(config)# ssh 0.0.0.0 0.0.0.0 inside

! Chiffrer les mots de passe
ASA-SIEGE(config)# password encryption aes
ASA-SIEGE(config)# service password-encryption
```

⚠ mot de passe pour le pare-feu : **AsaSuc2**

Routeur du Siège (R1-SUCCESSOR)

```
! Passer en mode privilégié et configuration globale
R1-SIEGE> enable
R1-SIEGE# configure terminal

! Définir le hostname
R1-SIEGE(config)# hostname R1-SIEGE

! Définir le domaine
R1-SIEGE(config)# ip domain-name R1_siege.com

! Configurer le mot de passe enable (mode privilégié)
R1-SIEGE(config)# enable secret R3Suc2
! Configurer la console avec le mot de passe
R1-SIEGE(config)# line console 0
R1-SIEGE(config-line)# password R3Suc2
R1-SIEGE(config-line)# login
R1-SIEGE(config-line)# exit

! Configurer les lignes VTY pour SSH en utilisant l'authentification locale
R1-SIEGE(config)# line vty 0 4
R1-SIEGE(config-line)# login local
R1-SIEGE(config-line)# transport input ssh
R1-SIEGE(config-line)# exit

! Générer les clés RSA (choisir 2048 bits)
R1-SIEGE(config)# crypto key generate rsa modulus 2048

! Créer le compte admin local avec un mot de passe complexe (ici R1/siege)
R1-SIEGE(config)# username admin secret R3Suc2

! Forcer l'utilisation de SSH en version 2 et activer le chiffrement des mots de passe
R1-SIEGE(config)# ip ssh version 2
R1-SIEGE(config)# service password-encryption

! Sauvegarder la configuration
R1-SIEGE(config)# end
R1-SIEGE# write memory
```

⚠ mot de passe pour le routeur : **R3Suc2**

Switch de couche 3 (L3-SUCCESSALE)

```
L3-SIEGE(config)# line console 0
L3-SIEGE(config-line)# password L3Suc2
L3-SIEGE(config-line)# login
L3-SIEGE(config-line)# exit

! Configurer les lignes VTY pour SSH avec authentification locale
L3-SIEGE(config)# line vty 0 4
L3-SIEGE(config-line)# login local
L3-SIEGE(config-line)# transport input ssh
L3-SIEGE(config-line)# exit

! Définir le domaine pour générer les clés RSA
L3-SIEGE(config)# ip domain-name L3_suc.com

! Générer les clés RSA (2048 bits)
L3-SIEGE(config)# crypto key generate rsa modulus 2048

! Créer le compte admin
L3-SIEGE(config)# username admin secret L3Suc2

! Forcer SSH version 2 et activer le chiffrement des mots de passe
L3-SIEGE(config)# ip ssh version 2
L3-SIEGE(config)# service password-encryption

! Sauvegarder la configuration
L3-SIEGE(config)# end
L3-SIEGE# copy running-config startup-config
```

⚠ mot de passe pour le switch de couche 3 : **L3Suc2**

Routeur Haut (Internet)

```
R2-HAUT> enable
R2-HAUT# configure terminal

! Définir le nom d'hôte et le domaine
R2-HAUT(config)# hostname R2-HAUT
R2-HAUT(config)# ip domain-name R2_haut.com

! Configurer le mot de passe enable
R2-HAUT(config)# enable secret R2Haut
```

```
! Configuration de la console
R2-HAUT(config)# line console 0
R2-HAUT(config-line)# password R2Haut
R2-HAUT(config-line)# login
R2-HAUT(config-line)# exit

! Configuration des lignes VTY pour SSH (authentification locale)
R2-HAUT(config)# line vty 0 4
R2-HAUT(config-line)# login local
R2-HAUT(config-line)# transport input ssh
R2-HAUT(config-line)# exit

! Générer les clés RSA (2048 bits)
R2-HAUT(config)# crypto key generate rsa modulus 2048

! Créer le compte admin local
R2-HAUT(config)# username admin secret R2Haut

! Forcer l'utilisation de SSH version 2 et activer le chiffrement des mots de passe
R2-HAUT(config)# ip ssh version 2
R2-HAUT(config)# service password-encryption

! Sauvegarder la configuration
R2-HAUT(config)# end
R2-HAUT# write memory
```

⚠ mot de passe pour le routeur: **R2Haut**

3/ Installation et Configuration de Base de Nginx sur Ubuntu

1.1. Mise à jour du Système et Installation de Nginx

Ouvrez un terminal sur votre machine Ubuntu et exécutez les commandes suivantes :

```
sudo -s  
mdp : proctr00  
apt update  
apt install nginx -y
```

Ces commandes mettent à jour la liste des paquets, installent les mises à jour disponibles et installent Nginx.

Configuration de Nginx :

Sous Ubuntu, la configuration par défaut se trouve dans `/etc/nginx/sites-available/default`. Vous pouvez modifier ce fichier pour y définir votre site. Par exemple, remplacez ou complétez le bloc `server` :

```
server {  
    listen 80 default_server;  
    listen [::]:80 default_server;  
  
    server_name monsite.com;  
  
    root /var/www/html;  
    index index.html;  
  
}
```

Vérification et rechargement de Nginx :

```
sudo nginx -t  
sudo systemctl reload nginx
```

2. Sécurisation de Nginx avec TLS/SSL

2.1. Génération d'un Certificat SSL

Certificat Auto-signé

Générez un certificat auto-signé avec OpenSSL :

```
sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 \  
-keyout /etc/ssl/private/nginx-selfsigned.key \  
-out /etc/ssl/certs/nginx-selfsigned.crt
```

2.2. Configuration de Nginx pour HTTPS

Modifiez le fichier de configuration pour ajouter un bloc `server` écoutant sur le port 443. éditez à nouveau le fichier `/etc/nginx/sites-available/default` :

```
server {  
    listen 443 ssl http2 default_server;  
    listen [::]:443 ssl http2 default_server;  
  
    server_name monsite.com;  
  
    root /var/www/html;  
    index index.html;  
  
    # Chemins vers le certificat et la clé (adapter selon l'option choisie)  
    ssl_certificate /etc/ssl/certs/nginx-selfsigned.crt;  
    ssl_certificate_key /etc/ssl/private/nginx-selfsigned.key;  
    ssl_dhparam /etc/ssl/certs/dhparam.pem;  
  
    # Protocoles et suites de chiffrement recommandés  
    ssl_protocols TLSv1.2 TLSv1.3;  
    ssl_prefer_server_ciphers on;  
    ssl_ciphers HIGH:!aNULL:!MD5;  
  
}
```

Vérifiez la syntaxe et rechargez Nginx :

```
sudo nginx -t  
sudo systemctl reload nginx
```

En recherchant notre site sur firefox nous voyons qu'ils y a un risques pour la sécurité :

Pour voir si le certificat est bien ici :

- Cliquez sur le cadena
- Cliquez sur connexion non sécurisée
- Cliquez sur afficher le certificat

3. Redirection de HTTP vers HTTPS

Pour forcer le trafic HTTP vers HTTPS, ajouter le bloc `server` écoutant sur le port 80 dans `/etc/nginx/sites-available/default` :

```
server {  
    listen 80 default_server;  
    listen [::]:80 default_server;  
  
    server_name monsite.com;  
  
    # Redirection permanente vers HTTPS  
    return 301 https://$host$request_uri;  
}
```

Vérifiez et rechargez la configuration :

```
sudo nginx -t  
sudo systemctl reload nginx
```

4. Configuration des En-têtes de Sécurité

Pour renforcer la sécurité, ajoutez les en-têtes suivants dans le bloc `server` du fichier écoutant sur le port 443 :

```
# HTTP Strict Transport Security (HSTS)
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains;
preload" always;

# Empêcher le MIME sniffing
add_header X-Content-Type-Options nosniff always;

# Protection contre les attaques XSS
add_header X-XSS-Protection "1; mode=block" always;

# Protection contre le clickjacking
add_header X-Frame-Options DENY always;

# Politique de referrer
add_header Referrer-Policy "no-referrer-when-downgrade" always;
```

5. Résultat final de la configuration :

```
server {
    listen 80 default_server;
    listen [::]:80 default_server;
    server_name monsite.com;

    # Redirection permanente vers HTTPS
    return 301 https://$host$request_uri;
}

server {
    listen 443 ssl http2 default_server;
    listen [::]:443 ssl http2 default_server;
    server_name monsite.com;

    root /var/www/html;
    index index.php; # Utilisation du front controller

    # Chemins vers le certificat et la clé SSL
    ssl_certificate /etc/ssl/certs/nginx-selfsigned.crt;
```

```
ssl_certificate_key /etc/ssl/private/nginx-selfsigned.key;
ssl_dhparam /etc/ssl/certs/dhparam.pem;

# Protocoles et suites de chiffrement recommandés
ssl_protocols TLSv1.2 TLSv1.3;
ssl_prefer_server_ciphers on;
ssl_ciphers
'TLS_AES_128_GCM_SHA256:TLS_AES_256_GCM_SHA384:ECDHE-ECDSA-AES128-
GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:ECDHE-ECDSA-AES256-GCM-
SHA384:ECDHE-RSA-AES256-GCM-SHA384';

# En-têtes de sécurité
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains;
preload" always;
add_header X-Content-Type-Options nosniff always;
add_header X-XSS-Protection "1; mode=block" always;
add_header X-Frame-Options DENY always;
add_header Referrer-Policy "no-referrer-when-downgrade" always;
add_header Content-Security-Policy "default-src 'self'; script-src 'self'; object-src
'none'; style-src 'self';" always;
add_header Expect-CT "max-age=86400, enforce, report-
uri='https://monsite.com/expect-ct-report'" always;

# Masquage des chemins via le front controller
location / {
    try_files $uri $uri /index.php?$query_string;
}

# Activation de PHP-FPM pour les fichiers PHP
location ~ \.php$ {
    try_files $uri =404;
    include snippets/fastcgi-php.conf;
    fastcgi_pass unix:/run/php/php8.1-fpm.sock;
    fastcgi_param SCRIPT_FILENAME $document_root$fastcgi_script_name;
    include fastcgi_params;
}

# Bloquer l'accès aux fichiers sensibles
location ~ /\. (ht|git|svn) {
    deny all;
}

# Bloquer l'accès aux fichiers de sauvegarde
location ~* \.(bak|backup|swp|swo|~)$ {
```



```
deny all;
}

# Bloquer l'accès aux fichiers et répertoires sensibles
location ~ /\. (git|svn|vti|htaccess|htpasswd) {
deny all;
access_log off;
log_not_found off;
}

# Désactivation de la compression pour éviter BREACH
gzip off;
}
```

Configuration du site connexion.php

Création des cookies, de la redirection vers la page de login si les utilisateurs ne sont pas connectés et du site web sécurisé.

```
<?php
session_set_cookie_params([
    'lifetime' => 0,
    'path' => '/',
    'domain' => "",
    'secure' => true,
    'httponly' => true,
    'samesite' => 'Strict'
]);
session_start();

// Vérifier si l'utilisateur est connecté
if (!isset($_SESSION['user_id'])) {
    // Rediriger vers la page de connexion si non authentifié
    header("Location: https://monsite.com/index.php");
    exit();
}
?>

<!DOCTYPE html>
```

```
<html lang="fr">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>SAE 401 - Sécurité</title>
  <link rel="stylesheet" href="style.css">
</head>
<body>
  <div class="container">
    <h1>Bienvenue sur notre site web sécurisé</h1>
    <p class="team">Réalisé par : Guyot Loïc, Sailliot Valentin, Jendryka Clément,
Poiré Pierre - RT2-A2</p>
  </div>
  <p class="footer">SAE 4.01 : Sécuriser un système d'information | IUT Béthune -
Université d'Artois | Encadrants : Mr Merchez et Mr Mercier</p>
</body>
</html>
```

Configuration de la page de redirection vers la page de connexion (index.html)

```
<!DOCTYPE html>
<html lang="fr">
<head>
  <meta charset="UTF-8">
  <meta http-equiv="refresh" content="3;url=index.php"> <!-- Redirection apr>
  <title>Page d'accueil</title>
</head>
<body>
  <h1>Bienvenue sur notre site</h1>
  <p>Vous allez être redirigé vers la page de connexion...</p>
</body>
</html>
```

Configuration de la page login "index.php"

Création du cookies, du Token CSRF, et des utilisateurs via mysql.

```
<?php
// Démarrage de la session et configuration sécurisée des cookies de session
session_set_cookie_params([
    'lifetime' => 0,
    'path' => '/',
    'domain' => "",
    'secure' => true,
    'httponly' => true,
    'samesite' => 'Strict'
]);

session_start();
// Paramètres de connexion à la base de données
$dsn = 'mysql:host=localhost;dbname=utilisateurs_db;charset=utf8';
$username_db = 'root';
$password_db = 'progr00';

try {
    // Créer une nouvelle instance PDO pour se connecter à la base de données
    $conn = new PDO($dsn, $username_db, $password_db);

    // Configuration des erreurs PDO (optionnel, mais recommandé pour le debug)
    $conn->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);
} catch (PDOException $e) {
    // En cas d'erreur de connexion, afficher le message d'erreur
    die("La connexion a échoué : " . $e->getMessage());
}

// Vérifie si l'utilisateur est déjà connecté
if (isset($_SESSION['user_id'])) {
    // Si l'utilisateur est déjà connecté, redirige-le vers la page principale du site
    header("Location: connexion.php");
    exit();
}

// Générer un token CSRF s'il n'existe pas
if (empty($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
}
```

```
}
?>

<!DOCTYPE html>
<html lang="fr">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Connexion</title>
  <link rel="stylesheet" href="style.css">
</head>
<body>
  <div class="container">
    <h2>Connexion</h2>
    <?php if (isset($_GET['error'])): ?>
      <p style="color:red;">Nom d'utilisateur ou mot de passe incorrect.</p>
    <?php endif; ?>
    <form action="login.php" method="POST">
      <label for="username">Nom d'utilisateur :</label>
      <input type="text" name="username" required>
      <br>
      <label for="password">Mot de passe :</label>
      <input type="password" name="password" required>
      <br>
      <!-- Champ caché pour le token CSRF -->
      <input type="hidden" name="csrf_token" value="<?php echo
htmlspecialchars($_SESSION['csrf_token'], ENT_QUOTES, 'UTF-8'); ?>">
      <button type="submit">Se connecter</button>
    </form>

    <!-- Bouton pour rediriger vers la page d'inscription -->
    <div style="margin-top: 10px;">
      <a href="inscription.php">
        <button type="button">S'inscrire</button>
      </a>
    </div>
  </div>
</body>
</html>
```

Configuration de la page d'inscription "inscription.php"

```
<?php
// Configuration sécurisée de la session
session_set_cookie_params([
    'lifetime' => 0,
    'path' => '/',
    'domain' => "",
    'secure' => true,
    'httponly' => true,
    'samesite' => 'Strict'
]);
session_start();

// Paramètres de connexion à la base de données
$dsn = 'mysql:host=localhost;dbname=utilisateurs_db;charset=utf8';
$username_db = 'root';
$password_db = 'progr00';

try {
    $pdo = new PDO($dsn, $username_db, $password_db, [
        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC
    ]);
} catch (PDOException $e) {
    die("Erreur de connexion à la base de données. Veuillez réessayer plus tard.");
}

// Générer un token CSRF s'il n'existe pas
if (empty($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
}

// Gestion de l'inscription
if ($_SERVER["REQUEST_METHOD"] === "POST" && isset($_POST['register'])) {
    // Vérification du token CSRF
    if (!isset($_POST['csrf_token']) || $_POST['csrf_token'] !==
        $_SESSION['csrf_token']) {
        die("Token CSRF invalide.");
    }

    $username = trim($_POST['new_username']);
    $password = $_POST['new_password'];

    // Vérification de la robustesse du mot de passe
    if (!preg_match('/^(?=.*[A-Z])(?=.*\d){8,}$/', $password)) {
        die("Mot de passe trop faible. Il doit contenir au moins 8 caractères, une majuscule
et un chiffre.");
    }
}
```

```
// Vérifier si l'utilisateur existe déjà
$stmt = $pdo->prepare("SELECT id FROM utilisateurs WHERE username = ?");
$stmt->execute([$username]);
if ($stmt->fetch()) {
    die("Nom d'utilisateur déjà pris.");
}

// Hacher le mot de passe
$hashed_password = password_hash($password, PASSWORD_BCRYPT);

// Insérer dans la base de données
$stmt = $pdo->prepare("INSERT INTO utilisateurs (username, password_hash)
VALUES (?, ?)");
if ($stmt->execute([$username, $hashed_password])) {
    // Rediriger vers la page de connexion après inscription réussie
    header("Location: index.php");
    exit();
} else {
    die("Erreur lors de l'inscription.");
}
}
?>

<!DOCTYPE html>
<html lang="fr">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Inscription</title>
    <link rel="stylesheet" href="style.css">
</head>
<body>
    <div class="container">
        <h2>Inscription</h2>
        <form action="inscription.php" method="POST">
            <label for="new_username">Nom d'utilisateur :</label>
            <input type="text" name="new_username" required>
            <br>
            <label for="new_password">Mot de passe :</label>
            <input type="password" name="new_password" required>
            <br>
            <input type="hidden" name="csrf_token" value="<?php echo
htmlspecialchars($_SESSION['csrf_token'], ENT_QUOTES, 'UTF-8'); ?>">
            <button type="submit" name="register">S'inscrire</button>
        </form>
        <p>Déjà un compte ? <a href="index.php">Connectez-vous ici</a>.</p>
    </div>
</body>
</html>
```

Création du login.php pour la redirection :

Ajout de la casse

```
<?php
session_set_cookie_params([
    'lifetime' => 0,
    'path'    => '/',
    'domain'   => "",
    'secure'   => true,
    'httponly' => true,
    'samesite' => 'Strict'
]);
session_start();

// Paramètres de connexion à la base de données
$dsn = 'mysql:host=localhost;dbname=utilisateurs_db;charset=utf8';
$username_db = 'root';
$password_db = 'progtr00';

try {
    $pdo = new PDO($dsn, $username_db, $password_db, [
        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC
    ]);
} catch (PDOException $e) {
    die("Erreur de connexion à la base de données. Veuillez réessayer plus tard.");
}

// Vérification des tentatives de connexion
if (!isset($_SESSION['login_attempts'])) {
    $_SESSION['login_attempts'] = 0;
}

if ($_SERVER["REQUEST_METHOD"] === "POST") {
    // Vérifier le token CSRF
    if (!isset($_POST['csrf_token']) || $_POST['csrf_token'] !==
$_SESSION['csrf_token']) {
        die("Token CSRF invalide.");
    }

    // Limiter les tentatives de connexion
    if ($_SESSION['login_attempts'] >= 5) {
```

```
die("Trop de tentatives de connexion. Veuillez réessayer plus tard.");
}

// Assainir et récupérer les entrées utilisateur
$username = filter_input(INPUT_POST, 'username', FILTER_SANITIZE_STRING);
$password = $_POST['password'];

// Requête pour vérifier si l'utilisateur existe (en tenant compte de la casse)
$stmt = $pdo->prepare("SELECT id, password_hash FROM utilisateurs WHERE
BINARY username = ?");
$stmt->execute([$username]);
$user = $stmt->fetch();

if ($user && password_verify($password, $user['password_hash'])) {
    // Réinitialiser les tentatives et régénérer l'ID de session pour éviter la fixation
    $_SESSION['login_attempts'] = 0;
    session_regenerate_id(true);

    $_SESSION['username'] = $username;
    $_SESSION['user_id'] = $user['id'];

    // Régénérer un token CSRF après connexion
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));

    // Rediriger vers la page principale
    header("Location: https://monsite.com/connexion.php");
    exit();
} else {
    $_SESSION['login_attempts']++;
    header("Location: https://monsite.com/index.php?error=true");
    exit();
}
}
?>

// Générer un token CSRF s'il n'existe pas déjà
if (!isset($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
}
?>
```


Mise en place du nom de domaine (DNS) :

```
apt install bind9 -y
mkdir /etc/bind/zones
```

```
nano /etc/bind/named.conf.local

zone "monsite.com" {
    type master;
    file "/etc/bind/zones/db.monsite.com";
};

zone "25.31.192.in-addr.arpa" {
    type master;
    file "/etc/bind/zones/db.192.31.25";
};
```

```
nano /etc/bind/zones/db.monsite.com

$TTL 604800
@      IN      SOA  ns1.monsite.com. admin.monsite.com. (
                        2      ; Serial
                        604800 ; Refresh
                        86400  ; Retry
                        2419200 ; Expire
                        604800 ) ; Negative Cache TTL

; Déclaration du ou des serveurs de noms
      IN      NS     ns1.monsite.com.

; Enregistrement A pour le serveur de noms
ns1    IN      A      192.31.25.11

; Enregistrements A pour d'autres services
      IN      NS     ns.monsite.com.
@      IN      A      192.31.25.11
ns     IN      A      192.31.25.11
www    IN      A      192.31.25.11
```

```
nano /etc/bind/zones/db.192.31.25

$TTL 604800
@      IN      SOA  ns.monsite.com. admin.monsite.com. (
                        1      ; Serial (à incrémenter lors des modificati>
                        604800      ; Refresh
                        86400      ; Retry
                        2419200    ; Expire
                        604800 )    ; Negative Cache TTL

; Enregistrements pour la résolution inverse
      IN      NS    ns.monsite.com.
11     IN      PTR   monsite.com.
11     IN      PTR   ns.monsite.com.
```

```
systemctl restart bind9
```

Création de la BDD via Mysql :

Création des mots de passe avant de les hachés :

```
touch hash.php
<?php
echo password_hash("Progr00", PASSWORD_BCRYPT) . PHP_EOL;

echo password_hash("SecurePass123", PASSWORD_BCRYPT) . PHP_EOL;

echo password_hash("progr00", PASSWORD_BCRYPT) . PHP_EOL;
?>
```

Installer ensuite Mysql, puis créer la table utilisateurs avec les mots de passes hachés récupérer sur le dossier hash.php

```
sudo apt install mysql-server -y

mysql -u root -p

USE utilisateurs_db
```

```
INSERT INTO utilisateurs (username, password_hash) VALUES  
('user1', '$2y$10$rMvbgJzGDINEUh/uQ/cBuj0hKJKr8Awtn4X9TCxDky7fgbXQ906.');
```

```
('user2', '$2y$10$hBMTmOYMcXgunezqqyullOtpwHXyMIBqc3mEWlaRaKu5YCrA3rJx6');  
('user3', '$2y$10$PXtVgXEvnVVt9xL2D/O5Duuxhyn6lc0YKMJLJyx7gHjeZctxl.y0u');
```

Pour voir si les utilisateurs existe :

```
SELECT * FROM utilisateurs;
```

4/ Sécurisation DNS avec DNSSEC

1. Objectifs

- **Installer et configurer** un serveur DNS sous Ubuntu en utilisant Bind9.
- **Signer une zone DNS** avec DNSSEC pour garantir l'intégrité et l'authenticité des enregistrements.
- **Vérifier la configuration** à l'aide d'outils d'analyse (dig, Wireshark) et comprendre la chaîne de confiance (root - TLD - domaine).

2. Environnement

- **Serveur DNS** : Ubuntu Server, Bind9 installé.
- **Client(s)** : Machines ou VMs dans le réseau local configurées pour interroger le serveur DNS.
- **Réseau** : Local, derrière une RT-Box (similaire au TP HTTPS).

3. Installation et Configuration Initiale du Serveur DNS

3.1 Installation de Bind9

Sur le serveur, exécutez :

```
sudo apt-get update  
sudo apt-get install bind9
```

Vérifiez que le service Bind9 est lancé :

```
systemctl status bind9
```

N'oubliez pas de configurer les forwarders dans le fichier `/etc/bind/named.conf.options`.

3.2 Test de la résolution locale

Depuis le serveur, vérifiez la résolution via :

```
dig google.com @127.0.0.1
```

4. Configuration Basique de la Zone DNS

4.1 Déclaration de la Zone

Dans le fichier `/etc/bind/named.conf.local`, ajoutez :

```
zone "dnssec.local" {  
    type master;  
    file "/etc/bind/db.dnssec.local";  
};
```

Cela indique que le serveur est maître pour la zone `dnssec.local` et qu'il utilisera le fichier signé.

4.2 Fichier de Zone Non-Signée

Créez le fichier `/etc/bind/db.dnssec.local` avec le contenu suivant :

```
$TTL 86400  
@   IN  SOA ns1.dnssec.local. admin.dnssec.local. (  
    2025020601 ; Serial (à incrémenter à chaque modification)  
    3600       ; Refresh  
    1800       ; Retry  
    604800     ; Expire  
    86400      ; Negative Cache TTL  
)  
   IN  NS  ns1.dnssec.local.  
  
ns1 IN  A   192.31.25.12    ; Adresse IP de votre serveur DNS  
www  IN  A   192.31.25.13    ; Adresse IP d'une machine fictive  
      (client)  
  
$INCLUDE "/etc/bind/Kdnssec.local.+008+35464.key"  
$INCLUDE "/etc/bind/Kdnssec.local.+008+58450.key"
```

Les fichiers de clés générés (*Kdnssec.local.+008+35464.* et *Kdnssec.local.+008+58450.*) proviennent de la commande `dnssec-keygen`.

4.3 Redémarrage du service Bind9

Après modification, redémarrez Bind9 :

```
sudo systemctl restart bind9
```

Testez la résolution de la zone depuis un client :

```
dig www.dnssec.local @192.31.25.12
```

Vous devez obtenir une réponse avec l'IP 192.31.25.13.

5. Mise en Place de DNSSEC

5.1 Génération des Clés

Dans le répertoire `/etc/bind`, générez les clés :

- Pour la ZSK (Zone Signing Key) :

```
sudo dnssec-keygen -a RSASHA256 -b 2048 -n ZONE dnssec.local
```

- Pour la KSK (Key Signing Key) :

```
sudo dnssec-keygen -f KSK -a RSASHA256 -b 2048 -n ZONE  
dnssec.local
```

Les fichiers générés auront des noms du type :

- `Kdnssec.local.+008+35464.key` et
`Kdnssec.local.+008+35464.private` (ZSK)
- `Kdnssec.local.+008+58450.key` et
`Kdnssec.local.+008+58450.private` (KSK)

5.2 Signature de la Zone

Pour signer la zone, exécutez :

```
sudo dnssec-signzone -o dnssec.local /etc/bind/db.dnssec.local
```

Un nouveau fichier signé est créé, par exemple :

- `/etc/bind/db.dnssec.local.signed`

5.3 Mise à Jour de la Configuration

Dans `/etc/bind/named.conf.local`, la zone doit pointer vers le fichier signé :

```
zone "dnssec.local" {  
    type master;  
    file "/etc/bind/db.dnssec.local.signed";  
};
```

Redémarrez Bind9 et vérifiez qu'aucune erreur n'apparaît.

6. Configuration pour sécurisation supplémentaire

6.1 Limitation d'accès aux requêtes DNS (ACL)

Ce qu'il faut ajouter dans `/etc/bind/named.conf.options` :

Dans la section `options`, ajoutez les directives suivantes pour restreindre l'accès :

```
options {
    directory "/var/cache/bind";

    // Définir une ACL pour autoriser seulement certaines adresses
    IP
    allow-query { localhost; 192.31.25.0/24; };
    allow-recursion { localhost; 192.31.25.0/24; };

    forwarders {
        172.18.26.101;
        172.18.26.102;
        172.18.26.103;
    };

    dnssec-validation auto;
    managed-keys-directory "/var/cache/bind";

    listen-on-v6 { none; };
    listen-on { any; };
};
```

6.2 Renforcer la sécurité du système d'exploitation

Recommandations et commandes à ajouter dans votre documentation :

- Mise à jour régulière du système :

```
sudo apt update
```

- Configuration d'un pare-feu (UFW) pour autoriser uniquement les ports nécessaires (53 UDP/TCP pour DNS, 22 SSH, etc.) :

```
sudo apt install ufw -y
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 53/tcp
sudo ufw allow 53/udp
sudo ufw allow 22/tcp
sudo ufw enable
```

6.3 Sauvegardes et redondance

Script de sauvegarde automatique :

Créez un script (ex. `/etc/bind/backup_bind.sh`) :

```
#!/bin/bash
DATE=$(date +%F_%H-%M)
BACKUP_DIR="/etc/bind/backup"
mkdir -p $BACKUP_DIR
tar -czvf $BACKUP_DIR/bind_backup_$DATE.tar.gz /etc/bind
```

Rendez-le exécutable :

```
sudo chmod +x /etc/bind/backup_bind.sh
```

Planifiez une tâche cron pour réaliser ces sauvegardes régulièrement (par exemple, tous les jours à 3h du matin) :

```
sudo crontab -e
```

Ajoutez :

```
0 3 * * * /etc/bind/backup_bind.sh >> /var/log/backup_bind.log  
2>&1
```

6.4 Surveillance et alertes

Installation de Fail2Ban pour protéger Bind9 :

Fail2Ban peut surveiller les logs de Bind9 et bloquer les adresses IP suspectes.

Installez Fail2Ban :

```
sudo apt install fail2ban -y
```

Créez un fichier de filtre spécifique pour Bind9 (ex. `/etc/fail2ban/filter.d/bind9.conf`) :

```
[Definition]  
failregex = client <HOST>#.*: query: .* REFUSED
```

Créez une jail pour Bind9 dans `/etc/fail2ban/jail.local` :

```
[bind9]
enabled = true
port    = 53,22
protocol = tcp,udp
filter  = bind9
logpath = /var/log/syslog
maxretry = 5
bantime = 3600

[DEFAULT]
banaction = iptables-multiport
banaction_allports = iptables-multiport
```

Redémarrez Fail2Ban :

```
sudo systemctl restart fail2ban
```

7. Vérification de la Configuration DNSSEC

7.1 Vérification avec dig

Sur un client, exécutez :

```
dig +dnssec www.dnssec.local @192.31.25.12
```

Vérifiez la présence des enregistrements RRSIG dans la réponse.

Pour vérifier les DNSKEY, utilisez :

```
dig +multiline @192.31.25.12 dnssec.local DNSKEY
```

Les réponses doivent contenir les clés et signatures (RRSIG).

7.2 Analyse avec Wireshark

- Lancez Wireshark sur le client.
- Capturez une requête DNS avec l'option +dnssec.
- Vérifiez la présence du bit DO (DNSSEC OK) et des enregistrements RRSIG, DNSKEY, et DS dans les réponses.

8. Structure des Fichiers de Configuration

La structure finale dans le répertoire /etc/bind/ doit ressembler à :

```
/etc/bind/
├── backup
├── backup_bind.sh
├── db.dnssec.local      (fichier de zone non signée)
├── db.dnssec.local.signed (fichier de zone signée)
├── Kdnssec.local.+008+35464.key
├── Kdnssec.local.+008+35464.private
├── Kdnssec.local.+008+58450.key
├── Kdnssec.local.+008+58450.private
├── named.conf.local     (zone "dnssec.local" pointant sur db.dnssec.local.signed)
├── named.conf.options   (avec forwarders, dnssec-validation auto, etc.)
└── named.conf.default-zones
```

9. Conclusion

Ce TP a permis de :

- Installer et configurer Bind9 pour servir une zone DNS locale.
- Mettre en place DNSSEC en générant une ZSK et une KSK, et en signant la zone.
- Configurer la validation DNSSEC côté client pour assurer la chaîne de confiance.
- Vérifier la configuration à l'aide d'outils comme dig et Wireshark.

Grâce à cette démarche, l'intégrité et l'authenticité des données DNS sont assurées, et la chaîne de confiance DNSSEC est mise en œuvre depuis le serveur racine jusqu'à votre domaine.

10. Fichiers de configurations

/etc/bind/db.dnssec.local

\$TTL 86400

```
@    IN  SOA ns1.dnssec.local. admin.dnssec.local. (
        2025020601 ; Serial (à incrémenter à chaque modif)
        3600       ; Refresh
        1800       ; Retry
        604800     ; Expire
        86400 )    ; Negative Cache TTL
```

```
      IN  NS  ns1.dnssec.local.
```

```
ns1 IN  A   192.31.25.12 ; Adresse IP de votre serveur DNS
www  IN  A   192.31.25.13 ; Adresse IP d'une future machine "www"
fictive (client)
```

\$INCLUDE "/etc/bind/Kdnssec.local.+008+35464.key"

\$INCLUDE "/etc/bind/Kdnssec.local.+008+58450.key"

Fichier auto-signé :

db.dnssec.local.signed

Fichiers pour les clés :

Kdnssec.local.+008+35464.key

Kdnssec.local.+008+35464.private

Kdnssec.local.+008+58450.key

Kdnssec.local.+008+58450.private

/etc/bind/named.conf

```
// This is the primary configuration file for the BIND DNS server
named.
//
// Please read /usr/share/doc/bind9/README.Debian.gz for information
on the
// structure of BIND configuration files in Debian, *BEFORE* you
customize
// this configuration file.
//
// If you are just adding zones, please do that in
/etc/bind/named.conf.local

include "/etc/bind/named.conf.options";
include "/etc/bind/named.conf.local";
include "/etc/bind/named.conf.default-zones";
```

/etc/bind/named.conf.default-zones

```
// prime the server with knowledge of the root servers
zone "." {
    type hint;
    file "/usr/share/dns/root.hints";
};

// be authoritative for the localhost forward and reverse zones, and
for
// broadcast zones as per RFC 1912

zone "localhost" {
    type master;
    file "/etc/bind/db.local";
};

zone "127.in-addr.arpa" {
    type master;
    file "/etc/bind/db.127";
};

zone "0.in-addr.arpa" {
    type master;
    file "/etc/bind/db.0";
};

zone "255.in-addr.arpa" {
    type master;
    file "/etc/bind/db.255";
};
```



```
/etc/bind/named.conf.local
```

```
zone "dnssec.local" {
    type master;
    file "/etc/bind/db.dnssec.local.signed";
};
```

```
/etc/bind/named.conf.options
```

```
options {
    directory "/var/cache/bind";

    // If there is a firewall between you and nameservers you want
    // to talk to, you may need to fix the firewall to allow
multiple
    // ports to talk.  See http://www.kb.cert.org/vuls/id/800113

    // If your ISP provided one or more IP addresses for stable
    // nameservers, you probably want to use them as forwarders.
    // Uncomment the following block, and insert the addresses
replacing
    // the all-0's placeholder.

    forwarders {
        172.18.26.101;
        172.18.26.102;
        172.18.26.103;
    };

    //=====
=====
    // If BIND logs error messages about the root key being
expired,
    // you will need to update your keys.  See
https://www.isc.org/bind-keys
    //=====
=====
    dnssec-validation auto;
    managed-keys-directory "/var/cache/bind";
```

```
listen-on-v6 { none; };  
listen-on { any; };  
};
```

/etc/bind/zones.rfc1918

```
zone "10.in-addr.arpa"      { type master; file "/etc/bind/db.empty";  
};
```

```
zone "16.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "17.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "18.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "19.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "20.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "21.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "22.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "23.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "24.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "25.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "26.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "27.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "28.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "29.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };
```

```
zone "30.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };  
zone "31.172.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };
```

```
zone "168.192.in-addr.arpa" { type master; file  
"/etc/bind/db.empty"; };
```

```
/etc/bind/backup_bind.sh
```

```
#!/bin/bash  
DATE=$(date +%F_%H-%M)  
BACKUP_DIR="/etc/bind/backup"  
mkdir -p $BACKUP_DIR  
tar -czvf $BACKUP_DIR/bind_backup_$(DATE).tar.gz /etc/bind
```

5/ Recommandations ANSSI : Checklist des mesures retenues, exclues ou non applicables.

https://docs.google.com/spreadsheets/d/19Q_J8CxREly1xwGRIVYHwjc4oIYJbx_a/edit?usp=sharing&ouid=100503642062115296665&rtpof=true&sd=true